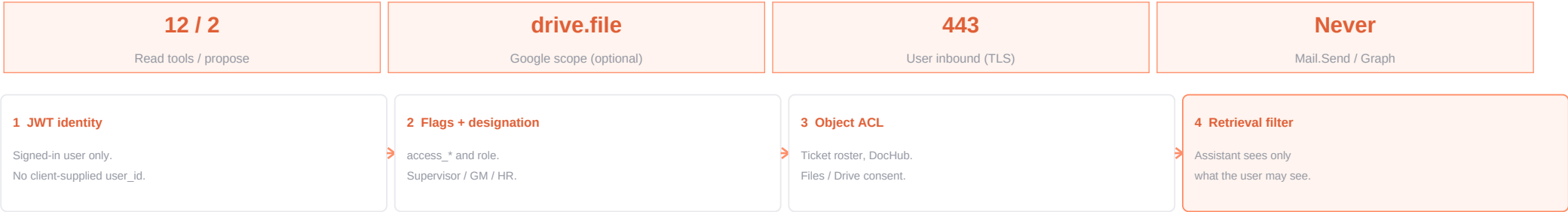


IT AND SECURITY REVIEW

Agent Connectivity, Permissions & Attributes

What Kynvera connects to, what Ask Kynvera may read and propose, and least-privilege permissions for optional Google Drive, email, and object storage. Not a Microsoft 365 tenant agent. No Global Admin, Sites.Read.All, Mail.Send, or WhatsApp.

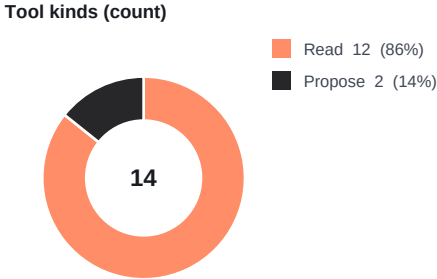


Ask Kynvera always runs as the signed-in JWT user. Background jobs use server configuration, except Drive sync which uses the connecting user’s stored OAuth token. Administrators grant or revoke module flags in Administration.

ASK KYNVERA — TOOL MATRIX

Read tools execute immediately. Write tools store a pending action until Confirm (15-minute TTL).

Tool	Kind	Touches	Access
get_pending_forms	Read	Pending reviewer items	Reviewer or admin
get_my_leave	Read	Own leave applications	Own rows
get_my_tickets	Read	Raised or assigned	access_ticketing
get_my_profile	Read	Own profile; admin person_name	Self; others = admin
search_documents	Read	Published DocHub	DocHub access
search_knowledge	Read	FAQ + admin KB + DocHub	Authenticated (filtered)
get_fm_critical_assets	Read	Critical / low-health assets	access_ticketing
get_fm_failures_by_building	Read	Failures by building	access_ticketing
get_fm_cost_trend	Read	Month vs prior costs	access_ticketing
get_fm_maintenance_report_hint	Read	How to generate MMR	Ticketing or report_generation
get_my_submissions / inspections	Read	Own form counts	Signed-in user
propose_create_ticket	Propose	Draft after Confirm	access_ticketing
propose_leave_draft	Propose	Leave draft — not submitted	HR path



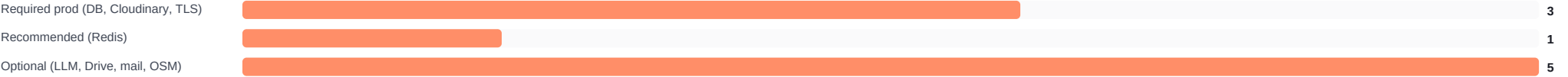
Out of scope: approve/reject workflow, close tickets, send mail, read/write Drive, payroll, passwords. AI triage is a separate preview/confirm API (TicketTriageLog). Source: module_assistant/agent.py tool registry.

PLATFORM INTEGRATIONS · GOOGLE OAUTH

Integration	Reads / writes	Required?	Scope	Why	Not requested
PostgreSQL	All operational data	Yes (production)	drive.file	Files this app created (Kynvera Files root)	drive / drive.readonly
Redis	Rate-limit counters / jobs	Strongly recommended	userinfo.email	Show connected Google account	Gmail, Contacts
Cloudinary	Images, signatures, DocHub files	Yes in production	openid	Link this Google login	Calendar, Docs-wide
Mail outbound	Reset, workflow, MMR	When email is needed			
Mail inbound	Subject/body → draft Ticket	Optional			
Google Drive	App-created tree under Kynvera Files	Optional; user consent			
LLM	Prompt + tool JSON → inference	Optional			
Nominatim / Leaflet	Geocode / map tiles	Optional			

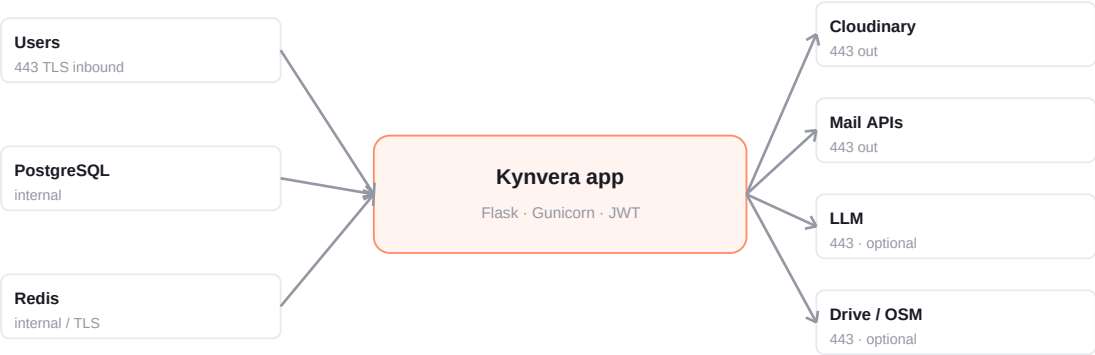
Microsoft Graph is not used. No Sites.Selected, Mail.ReadWrite, or Teams RSC.

Integration count by necessity

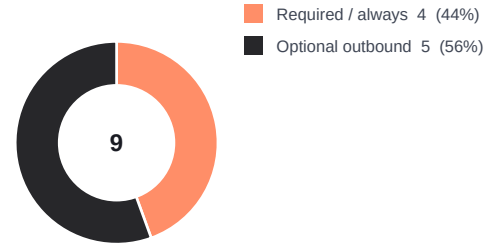


NETWORK

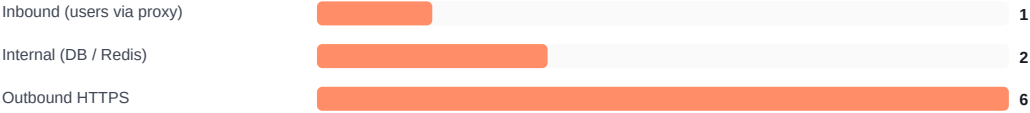
Almost all traffic is outbound HTTPS. No extra public inbound ports.



Network flows



Direction count



Flow	Dir	Port	When
Users / PWA / Capacitor	In	443 TLS	Always
PostgreSQL	App → DB	5432 / provider	Yes
Redis	App → Redis	6379 / rediss	Recommended
Cloudinary	Out	443	Production
Mailjet / Brevo	Out	443	If email
SMTP alt.	Out	587 STARTTLS	If SMTP
LLM endpoint	Out	443	If LLM
Google OAuth + Drive	Out	443	If Drive
Nominatim	Out	443	If geocode

RBAC · BOUNDARIES · HUMAN APPROVAL

Role	Tickets	Assistant writes	Admin
Field / user	Own raised / assigned	Ticket draft if flagged; leave draft	—
Supervisor	Roster / email drafts	Per flags	—
Operations manager	As configured	Per flags	—
Procurement	As flagged	No commercial tool	—
HR / HR manager	—	Own leave draft	HR tools
General manager	As configured	Per flags	—
Administrator	All	Allowed tools + profile lookup	Yes

Never requested	Never accessed	Human gate	Rule
Microsoft Global Admin / Graph	Full Google Drive or Gmail	Chat ticket	Draft after Confirm, then supervisor workflow
Mail.Send	WhatsApp	Leave from chat	Draft only until HR form is signed
Sites.Read.All	Payroll / bank files	Email intake	Stays draft until supervisor converts
Unrestricted DB chat	Automatic client-portal submit	Drive	User consents; IT can set GOOGLE_DRIVE_ENABLED=false
		Application mail	Server-side reset / workflow / MMR only

Ticket ACL: access_ticketing does not mean every ticket. Visibility is reporter, assignee, technician, supervisor, or supervised project. Review with Architecture Deck and IT Clarification Answer Matrix.